

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture you will be able to explain the four pillars of identity and access management — identification, authentication, authorisation, and accounting — and describe how they collectively control access in cloud environments.
- By the end of this lecture you will be able to apply the principle of least privilege using role-based and attribute-based access control models, and articulate why over-privileged credentials amplify breach impact.
- By the end of this lecture you will be able to describe how cloud network security uses segmentation, zero trust, and micro-segmentation to contain threats that pass the perimeter.
- By the end of this lecture you will be able to explain virtualisation security risks including hypervisor compromise and VM escape, and describe the controls that prevent them.
- By the end of this lecture you will be able to distinguish privileged access management from ordinary least-privilege controls and explain why federation and single sign-on reduce credential sprawl risk.

Introduction

Most cloud breaches follow a predictable anatomy. An attacker finds a weakness at one layer, gains a foothold, and then moves freely because the layers beneath and beside that entry point were never secured independently. The three security disciplines covered in this lecture — identity and access management, network security, and virtualisation security — are designed to prevent exactly that pattern. Each creates a distinct boundary, and together they produce a layered defence where a failure at one layer does not automatically cascade into a catastrophe.

This lecture draws on a well-documented 2019 breach at a major financial institution in which an attacker exploited a misconfigured web application to obtain cloud server credentials, then used those over-privileged credentials to exfiltrate data belonging to over one hundred million customers. The incident illustrates every concept covered here: inadequate network controls allowed the initial misconfiguration, weak authorisation boundaries made the credentials enormously powerful, and absent micro-segmentation allowed the attacker to roam freely once inside. Understanding why each layer failed in that case is the fastest route to understanding why each layer matters in your own environments.

For a Cloud Security Practitioner, these three disciplines are not background theory — they are the daily vocabulary of design reviews, architecture assessments, and incident investigations. The CCSP exam tests both definitional knowledge and applied reasoning across all three areas, so this guide builds both. It moves from the foundational four-step IAM model through practical network controls and into the hypervisor-level concerns that make multi-tenant cloud security fundamentally different from traditional data-centre security.

Core Concepts Explained

Identity and Access Management (IAM) — The Four Pillars

Definition: IAM governs who can access cloud resources and what they can do with that access. It comprises four sequential steps: identification (claiming an identity, such as entering a username), authentication (proving that claim, such as via password and MFA), authorisation (determining what the proven identity may do), and accounting (recording what was actually done).

Business relevance: IAM failures are the most common enabler of cloud breaches. When any of the four pillars is weak — unenforced MFA, overly broad authorisation, or absent logging — attackers can obtain access that looks indistinguishable from legitimate use, making detection and investigation far harder.

Cloud Security Practitioner relevance: A Cloud Security Practitioner designs and reviews IAM policies across all four pillars, enforces MFA on privileged and human accounts, audits authorisation boundaries against the least-privilege standard, and ensures that accounting logs are tamper-resistant, retained appropriately, and feeding a monitoring pipeline.

Real-world example: In the 2019 Capital One breach, a misconfigured web application firewall allowed an attacker to send a request that caused a cloud EC2 instance to retrieve its own IAM role credentials from the instance metadata service. Those credentials were not protected by MFA (authentication pillar weak), were scoped to broad S3 read access far beyond what the application required (authorisation pillar weak), and the access logs — while present — were not being monitored in near-real time (accounting pillar under-utilised). A practitioner conducting a quarterly IAM review would have flagged the over-broad role policy and the missing alerting, either of which, if remediated, would have broken the attack chain before data was exfiltrated.

Risks or limitations: Overly permissive IAM roles turn a small misconfiguration into a large breach. Missing MFA means a stolen password is sufficient for full account takeover. Absent or unreliable logs prevent post-incident reconstruction. Best practice is to audit IAM policies against a least-privilege baseline quarterly and use cloud-native policy analysis tools (such as AWS IAM Access Analyzer) to flag permissions that have not been used in 90 days.

Multi-Factor Authentication (MFA) and Least Privilege

Definition: MFA requires proof from at least two independent categories: something you know (password), something you have (hardware token or authenticator app), or something you are (biometric). Least privilege means every identity — human or machine — is granted only the minimum permissions required for its defined function, and nothing more.

Business relevance: MFA on its own eliminates the majority of credential-stuffing and phishing-driven account takeovers, because a stolen password without the second factor is useless. Least privilege limits the blast radius when any credential is compromised, turning a potentially catastrophic breach into a contained incident.

Cloud Security Practitioner relevance: A Cloud Security Practitioner ensures MFA is mandatory for all human accounts, particularly administrative ones, using conditional access policies where possible to require step-up authentication for sensitive operations. They also enforce least privilege through regular permission audits and use RBAC and ABAC to assign permissions by role or attribute rather than to individuals.

Real-world example: A financial services firm migrating to AWS assigned all developers an IAM group with full AdministratorAccess because it was the easiest way to remove friction during the migration. Six months later, a developer's laptop was compromised through a phishing email. The attacker used the developer's AWS CLI credentials — no MFA was enforced on programmatic access — to enumerate every S3 bucket in the account, discover an unencrypted customer database export, and download it. A Cloud Security Practitioner reviewing

the environment would have required MFA for CLI access via STS assume-role, removed AdministratorAccess from the developer group, and replaced it with scoped policies allowing only the services and actions genuinely used by that team.

Risks or limitations: Broad IAM permissions are often granted during migrations or under deadline pressure and then never revoked. The best practice is to treat permission grants as time-limited by default, review them at each sprint or release cycle, and use just-in-time access tools for any operation requiring elevated rights.

Cloud Network Security — Segmentation and Zero Trust

Definition: Cloud network security uses virtual constructs — security groups, network access control lists (NACLs), and software-defined networking — to divide a cloud environment into zones. Security groups act as stateful firewalls attached to individual resources; NACLs are stateless and operate at the subnet boundary. Zero trust is an architectural philosophy that removes the assumption of trust from any network location: every request must be authenticated and authorised regardless of its origin.

Business relevance: Traditional perimeter security is ineffective in the cloud because there is no meaningful perimeter — resources communicate across the public internet, with managed services, and with other tenants' environments. Segmentation limits lateral movement after a breach; zero trust eliminates the concept of a 'trusted' internal network entirely, ensuring that a compromised device or account cannot roam freely.

Cloud Security Practitioner relevance: A Cloud Security Practitioner defines security group rules that enforce least-privilege network access (only the ports and protocols a resource genuinely needs, from only the sources that legitimately need to reach it), implements NACLs as a secondary defence layer, and designs workload architecture to prevent unrestricted east-west traffic between tiers.

Real-world example: A large technology company — Google, under its BeyondCorp initiative — rebuilt its internal security model after a sophisticated 2009 nation-state attack (Operation Aurora) demonstrated that attackers inside the corporate network could move freely. BeyondCorp removed VPN-based internal trust entirely: employees access internal applications over the public internet, with every request evaluated against device posture, user identity, and context before access is granted. The result is that a compromised laptop on the corporate Wi-Fi has no more inherent trust than one in a coffee shop. Cloud architects who apply zero trust principles to workload-to-workload communication achieve the same effect: a server in the application tier can reach the database tier only on the specific port and protocol defined in the security group, authenticated with a service identity, regardless of whether it is on the same virtual network.

Risks or limitations: The most common network security failure is security group rules that allow 0.0.0.0/0 (all sources) on sensitive ports, either from an initial permissive configuration never tightened, or a temporary rule opened for testing and forgotten. Best practice is to use infrastructure-as-code for all network rules so every change is peer-reviewed, version-controlled, and automatically compared against a least-privilege policy baseline.

Micro-Segmentation and East-West Traffic Control

Definition: Micro-segmentation divides a cloud environment into fine-grained security zones — often at the individual workload or container level — and enforces access controls on traffic flowing between them (east-west traffic). This is distinct from perimeter controls that govern north-south traffic between the outside world and the environment.

Business relevance: Micro-segmentation converts a breach of a single workload from a network-wide incident into a contained event. Without it, an attacker with a foothold in one service can probe and attack every other service on the same virtual network, because the only controls in place are at the perimeter.

Cloud Security Practitioner relevance: A Cloud Security Practitioner maps the legitimate communication paths between workloads — web tier to application tier, application tier to database, etc. — and implements security group rules or service mesh policies that permit only those specific paths. All other east-west traffic is denied by default.

Real-world example: An e-commerce platform operated a three-tier architecture (web, application, database) in a single AWS VPC with a single security group that allowed all traffic between instances in the group. When an attacker exploited a server-side request forgery vulnerability in the web tier, they were able to directly query the database port from the compromised web server — because no rule prevented web-tier instances from reaching the database port. After the incident, the architecture team introduced separate security groups for each tier with explicit allow rules only for the required flows: web to app on port 443, app to database on port 5432. The same SSRF exploit, repeated after the change, reached the web instance but could not connect to the application or database tiers.

Risks or limitations: Micro-segmentation requires accurate network flow mapping before implementation; applying it incorrectly can break legitimate application communication. Best practice is to use a monitoring-only (audit) mode first to record all actual traffic flows, then derive the least-privilege rule set from observed behaviour rather than guesswork.

Virtualisation Security — Hypervisor and Container Isolation

Definition: Virtualisation is the technology that allows multiple virtual machines (VMs) to share a single physical host. The hypervisor is the software layer that creates and manages those VMs. A VM escape is the worst-case vulnerability: malicious code breaking out of a VM to reach the hypervisor or other VMs on the same host. Containers are a lighter virtualisation form that share the host operating system kernel rather than running a full separate OS; they offer less isolation than VMs.

Business relevance: In multi-tenant cloud environments, your VM may physically share a server with workloads belonging to other organisations. The hypervisor is the boundary between you and them. A hypervisor vulnerability that allows VM escape or cross-VM information leakage is a fundamental breach of the multi-tenancy model. Container isolation is thinner and depends heavily on the security of the shared kernel.

Cloud Security Practitioner relevance: A Cloud Security Practitioner cannot directly patch the cloud provider's hypervisor — that is the provider's responsibility. However, they can ensure that workloads running within VMs and containers are hardened, that container images are scanned for known vulnerabilities before deployment, that containers run with the minimum Linux capabilities and never as root, and that the organisation's workload placement and isolation requirements are addressed through dedicated hosts or confidential computing offerings where regulatory requirements demand stronger guarantees.

Real-world example: In 2018, researchers disclosed a class of CPU-level vulnerabilities — Spectre and Meltdown — that allowed code running in one VM to read memory belonging to other VMs on the same physical host by exploiting speculative execution in the CPU. Major cloud providers (AWS, Azure, Google Cloud) responded with emergency hypervisor patches and, in some cases, required reboots of customer VMs. Organisations running highly sensitive workloads on shared infrastructure had no independent ability to apply the fix — they were dependent on the provider's patching speed and transparency. This real incident underlines why the shared responsibility model requires trusting the provider's hypervisor security, and why organisations with the most sensitive workloads should consider dedicated hosts or confidential computing enclaves that provide hardware-level memory encryption.

Risks or limitations: Container images pulled from public registries frequently contain outdated or vulnerable packages. Best practice is to maintain a private image registry, scan every image with a vulnerability scanner

(such as Trivy or AWS ECR scanning) before it can be deployed, enforce image signing, and use admission controllers to block unsigned or high-severity images from running in the cluster.

Practical Applications

The following scenarios illustrate how Cloud Security Practitioners apply IAM, network security, and virtualisation security in day-to-day professional contexts.

Conducting an IAM Posture Review for a Cloud Migration

A Cloud Security Practitioner at a healthcare organisation is preparing for a compliance audit six months after a major AWS migration. She begins by pulling an IAM credential report and AWS Access Advisor data, which shows the last-used date for every permission assigned across every role. She discovers that fourteen IAM roles have permissions to services they have not accessed in over 180 days — a clear violation of least-privilege. She also finds three human IAM users with programmatic access keys but no MFA requirement on console access. Her remediation plan has two parts: she scripts a permission trimming pass using the Access Advisor data to remove unused service permissions from each role, and she enables an AWS IAM policy that denies all API calls from human users unless MFA was used in the current session. Before presenting findings to the audit team, she also verifies that CloudTrail logging is enabled in all regions and that logs are being shipped to a Security Information and Event Management platform with alerting for suspicious patterns. The audit passes with no significant findings.

Implementing Zero Trust Network Architecture for a SaaS Application

A Cloud Security Practitioner is engaged to redesign the network architecture of a multi-tier SaaS application that currently uses a flat VPC with a single catch-all security group. He begins by documenting the actual communication flows between services using VPC Flow Logs analysed over a two-week period. The data reveals that the payment processing service is reachable from the public-facing web tier — a path that should never exist. He redesigns the architecture into four isolated subnets (public, web, application, data), each with its own security group, and replaces the catch-all group with explicit rules: the web tier accepts HTTPS from the internet, the application tier accepts only from the web tier on a defined internal port, the data tier accepts only from the application tier on the database port, and the payment service is placed in its own isolated subnet with ingress permitted only from a dedicated payment orchestration function. He also implements AWS Network Firewall for deep packet inspection on traffic entering the environment. After the redesign, penetration testing confirms that a compromise of the web tier cannot reach the database or payment service directly.

Privileged Access Management for a Cloud Operations Team

A Cloud Security Practitioner at a regulated financial services firm is asked to redesign how the operations team accesses production cloud accounts. Currently, three engineers share a set of standing IAM administrator credentials stored in a shared password manager. She implements a PAM solution that integrates with AWS IAM Identity Center and the firm's Active Directory. Under the new model, no standing administrative credentials exist in production accounts. When an engineer needs elevated access, they submit a request through the PAM portal with a stated reason and expected duration; the request is automatically approved for routine operations and routed to a senior engineer for manual approval for riskier actions. The PAM system issues time-limited credentials scoped to only the services the approved request requires, and it records a full session audit trail. Credentials automatically expire at the end of the approved window. When the security team later reviews a potential incident in the production account, they can reconstruct exactly which engineer performed which API

calls, at what time, under which approved request — a capability that was entirely absent under the shared-credential model.

Best Practices

- **Enforce MFA on every human account without exception, including service accounts reachable via the console.** Configure cloud identity providers to deny console access unless MFA was satisfied in the current session. For programmatic access, require short-lived credentials obtained through role assumption with MFA enforcement rather than long-lived access keys. Review the MFA enforcement policy after every staff change to ensure departing users' bypass exceptions are not left in place.
- **Apply least privilege at the permission level, not just the role level, and review quarterly.** Use cloud-native tools (AWS IAM Access Analyzer, Azure Policy, GCP IAM Recommender) to identify permissions assigned but not used in 90 days. Remove unused permissions promptly. When authoring new IAM policies, begin with the minimum required and add only what application testing proves is needed — never start from a broad policy and attempt to restrict later, because restrictions are always forgotten under deadline pressure.
- **Treat security group rules as infrastructure code, reviewed and version-controlled like application code.** Store all security group and NACL configurations in an infrastructure-as-code repository (Terraform, CloudFormation). Require pull-request review for any change. Run automated policy checks — for example, deny any rule allowing 0.0.0.0/0 on sensitive ports — as part of the CI/CD pipeline so that over-permissive rules cannot be merged. Schedule a quarterly audit of rules against the current legitimate traffic flows recorded in VPC Flow Logs.
- **Replace standing privileged credentials with just-in-time access that is time-limited, approved, and fully logged.** No administrator should hold permanent, standing access to production systems. Implement a PAM workflow that issues temporary, scoped credentials upon approval, records the full session, and automatically revokes access when the window closes. Treat any long-lived administrative credential discovered outside this workflow as a security incident requiring immediate rotation and investigation.
- **Scan container images for vulnerabilities before they enter the deployment pipeline and enforce image signing.** Integrate a container vulnerability scanner into the CI/CD pipeline at the image build stage, blocking deployment of images with critical or high-severity vulnerabilities unless a documented exception is approved. Implement image signing (Docker Content Trust or Sigstore) and configure admission controllers to reject unsigned or unverified images from running in any cluster. Maintain a private registry rather than pulling from public sources in production.

Common Mistakes and Misconceptions

Misconception: Granting broad IAM administrator permissions to speed up a migration, with the intention of tightening them later — and then never doing so.

Correct approach: Apply least-privilege permissions from day one of a migration, even if it requires more initial effort to scope policies correctly. Use infrastructure-as-code to define permissions and schedule a post-migration permission audit within 30 days. The practice of 'we will tighten later' is the most reliably broken promise in cloud security.

Misconception: Treating a zero trust or segmentation project as complete once network rules are in place, without addressing identity verification for workload-to-workload traffic.

Correct approach: Zero trust applies to both human and machine identities. Implement service identities (IAM roles for EC2, managed identities for Azure VMs, Workload Identity for GKE) so that workload-to-workload calls are authenticated and authorised, not simply permitted by virtue of being on the same network segment.

Misconception: Assuming that cloud providers secure the entire stack, including the hypervisor, virtualisation layer, and workloads, leaving the customer with nothing to do.

Correct approach: Understand the shared responsibility model for each service type. The cloud provider secures the physical hypervisor and underlying fabric. The customer is responsible for the OS configuration inside VMs, the security of container images and runtime settings, IAM policies, network rules, and data encryption. Leaving workloads on default configurations is always the customer's choice and always a risk.

Misconception: Enabling detailed IAM and network logging but failing to connect those logs to an alerting system, so access anomalies are recorded but never acted on.

Correct approach: Logging without monitoring is an insurance policy you never file a claim on. Connect CloudTrail, VPC Flow Logs, and authentication logs to a SIEM or cloud-native monitoring service (AWS GuardDuty, Azure Sentinel, Google Security Command Center) with alerts configured for impossible-travel logins, API calls from unusual regions, and privilege escalation events. Test alert delivery monthly.

checklist: Cloud IAM and Network Security Configuration Checklist

Use this checklist during design reviews and quarterly security assessments to verify that the core IAM and network controls are in place. Each item maps to a specific risk from the lecture.

- ☐ MFA is enforced for all human accounts via an IAM policy that denies API access when MFA was not used in the current session.
- ☐ No long-lived IAM access keys exist for human users; programmatic access uses temporary credentials obtained via role assumption.
- ☐ All IAM roles have been reviewed against Access Advisor data in the last 90 days; unused permissions have been removed.
- ☐ Privileged access to production accounts is time-limited, request-approved, and session-logged via a PAM solution.
- ☐ Federation and single sign-on are configured so that a user's account can be disabled in one place (the identity provider) and access is revoked everywhere simultaneously.
- ☐ All security group rules are stored in version-controlled infrastructure code and pass automated policy checks before deployment.
- ☐ No security group rule allows unrestricted access (0.0.0.0/0) on sensitive ports (22, 3389, database ports) from the internet.
- ☐ East-west traffic between application tiers is restricted to the specific ports and protocols required; all other internal traffic is denied by default.
- ☐ Container images are scanned for vulnerabilities before deployment; images with critical findings are blocked by admission controllers.
- ☐ CloudTrail, VPC Flow Logs, and authentication logs are enabled across all regions and accounts, shipped to a centralised SIEM with active alerting.

How to use this: *This checklist is a minimum baseline. Environments handling regulated data (PHI, PII, financial records) require additional controls including dedicated hosts or confidential computing for sensitive workloads and quarterly penetration testing of network segmentation boundaries.*

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A Cloud Security Practitioner reviews the IAM roles for a web application that processes customer orders. One role assigned to the application's EC2 instances has permissions to read and write to all S3 buckets in the account, create IAM users, and terminate EC2 instances. The application only needs to read from one specific S3 bucket. Which control would most directly reduce the risk this over-permissive role represents?

- A) A. Enable MFA on the EC2 instance role so that every API call requires a second factor.
- B) B. Replace the broad role with a narrowly scoped policy granting only s3:GetObject on the specific bucket the application uses.
- C) C. Move the EC2 instances into a private subnet with no internet gateway.
- D) D. Enable VPC Flow Logs to record all API calls made by the application.

Answer: B. Replace the broad role with a narrowly scoped policy granting only s3:GetObject on the specific bucket the application uses.

Q2. An attacker obtains a valid developer's username and password through a phishing email. The developer's account does not have multi-factor authentication enabled on console access. What is the most effective control that would have prevented the attacker from using these stolen credentials to log into the cloud management console?

- A) A. A network access control list blocking the attacker's IP address.
- B) B. An IAM policy enforcing that all console sessions must have MFA satisfied.
- C) C. A security group preventing the attacker's region from reaching the application servers.
- D) D. Encryption of all data at rest in the cloud account.

Answer: B. An IAM policy enforcing that all console sessions must have MFA satisfied.

Q3. A company's web application tier and database tier run in the same VPC with a single security group that permits all traffic between members of the group. A penetration tester gains access to the web tier through an application vulnerability and immediately queries the database port directly from the compromised web server. Which architectural change would have most effectively prevented this lateral movement?

- A) A. Encrypting the database at rest with a customer-managed key.
- B) B. Enabling CloudTrail logging in all regions.
- C) C. Implementing separate security groups for each tier with rules permitting only the required port and source.
- D) D. Enabling GuardDuty to detect unusual API calls.

Answer: C. Implementing separate security groups for each tier with rules permitting only the required port and source.

Q4. A Cloud Security Practitioner is explaining hypervisor security to a cloud architecture team. Which statement most accurately describes the shared responsibility boundary for hypervisor security on a major public cloud IaaS platform?

- A) A. The customer is responsible for patching the hypervisor because they control the virtual machines running on top of it.
- B) B. The cloud provider secures the physical hypervisor and underlying infrastructure; the customer secures the operating systems, workloads, and data running within virtual machines.
- C) C. Hypervisor security is a shared control, meaning both the provider and customer apply patches on an agreed schedule.
- D) D. The customer bears full responsibility for hypervisor security when using dedicated hosts.

Answer: B. The cloud provider secures the physical hypervisor and underlying infrastructure; the customer secures the operating systems, workloads, and data running within virtual machines.

Q5. An operations engineer needs temporary administrator access to a production cloud account to investigate an incident. Under a robust privileged access management implementation, which sequence of events best describes how this access should be granted and used?

- A) A. The engineer uses a shared administrator password stored in the team's password manager, completes the investigation, and returns the password to the manager.
- B) B. The engineer's permanent IAM user account is elevated to administrator group membership for the duration of the incident, then manually removed.
- C) C. The engineer submits a request via the PAM portal with a justification and estimated duration; the system issues time-limited scoped credentials upon approval, records the session, and automatically revokes access at the end of the window.
- D) D. The engineer contacts the cloud provider's support team, who grant temporary root access to the account.

Answer: C. The engineer submits a request via the PAM portal with a justification and estimated duration; the system issues time-limited scoped credentials upon approval, records the session, and automatically revokes access at the end of the window.

Reflection Questions

1. Think about the identity controls in an environment you are familiar with. Are permissions granted by role or by individual, and when were they last reviewed against what is actually needed?
2. Consider how east-west traffic is controlled in a cloud workload you have encountered. If an attacker gained access to one component, which other components could they reach directly?
3. Reflect on the 2019 Capital One breach. At which of the four IAM pillars — identification, authentication, authorisation, or accounting — did the most significant failure occur, and what single control would have had the highest impact if it had been in place?
4. When you think about privileged access in a cloud environment, are there standing administrator credentials that exist today? If so, what would it take to move to a just-in-time model?
5. How does the concept of zero trust change the way you think about internal network traffic? What assumptions does your current architecture make that zero trust would challenge?
6. Containers and virtual machines offer different isolation guarantees. In the workloads you work with, is the isolation level appropriate for the sensitivity of the data being processed?

Key Takeaways

- IAM comprises four pillars — identification, authentication, authorisation, and accounting — and weaknesses in any one of them create exploitable risk.
- MFA is the single highest-return security control for human accounts; a stolen password without the second factor cannot complete authentication.
- Least privilege applies to every identity, human and machine, and should be enforced through RBAC or ABAC with regular reviews against actual usage data.
- Network segmentation and micro-segmentation limit lateral movement by restricting east-west traffic to only the paths that legitimate application flows require.
- Zero trust removes the concept of a trusted interior network; every request — regardless of its origin — must be authenticated and authorised.
- The hypervisor is the most security-critical component in the virtualisation stack; hypervisor compromise can affect every VM on the same physical host.
- Containers offer thinner isolation than VMs because they share the host OS kernel; container images must be scanned and run with minimal privileges.
- PAM extends least privilege to powerful administrator accounts by replacing standing credentials with just-in-time, time-limited, fully logged access.
- Federation and SSO centralise identity management, allowing MFA and deprovisioning to be enforced once and applied everywhere simultaneously.

Recommended Next Actions

Put this lecture to work within the next seven days:

7. Log into your cloud provider's IAM console and pull an Access Advisor or equivalent report. Identify any role or user with permissions that have not been exercised in 90 days and draft a plan to remove those permissions this sprint.
8. Review your current security group rules for any ingress rule that allows 0.0.0.0/0 on a port above 22 or on any database port. Document each finding and schedule remediation within the current quarter.
9. Map the east-west communication flows between your application tiers and verify that security group rules permit only those flows. Use VPC Flow Logs or equivalent to confirm the map matches actual traffic before and after any rule changes.
10. If your environment has standing administrator IAM users or shared credential sets for production access, identify a PAM solution and draft a proposal to replace them with just-in-time access this quarter.